FREE TOOLKIT · VERSION 1.0 - NOVEMBER 2026

# AI security risk add-on for banks in Qatar

Plugs into the risk register you already run. Adds the AI security content and the QCB and NCSA requirements, so there's nothing to rebuild.

**Abed Al Rahman Naboulsi**

Swipe →

ALREADY CERTIFIED?

# Good. This builds on it.

**What you may already run:**

- ISO/IEC 27001
- ISO/IEC 42001
- NIA v2.1
- QCSF
- PCI DSS
- SWIFT CSP

**What the add-on adds:**

**AI security scenarios and controls**
mapped to ISO/IEC 27001 and 42001 Annex A, NIA v2.1 statements and QCSF capabilities

**QCB requirements for AI**
AI Guideline, Cloud Computing, Data Handling and Protection, Incident Reporting

**The national layer**
EISRMF risk bands, NISRMF reporting and the NCSA submission calendar

*PCI DSS and SWIFT CSP stay in their own programmes; not mapped in v1.0. QCSF is used as good practice.*

SEVEN QUESTIONS

# What an existing register may not answer yet

1. Does it cover AI assets and AI threats?
2. Which requirements are mandatory, and which are good practice?
3. Do your ratings map to the national bands?
4. Which NIA controls does each AI system need?
5. Who approves and accepts AI risk?
6. What is due to QCB and NCSA, and when?
7. Can you evidence it for audit?

QUESTIONS 1 AND 4

# AI content, ready to load

**10**
AI asset types

**24**
AI threats, mapped to OWASP 2026 where covered

**42**
ready-made risk scenarios

**31**
AI controls with SoA mappings

**NIA by AI system**
Enter each system's C, I and A ratings: the sheet shows the baseline and additional NIA v2.1 controls it needs (2.3), and all 356 statements applied to AI.

QUESTION 2

# Mandatory or good practice?

Start with 13 Essentials, each tied to the source's own wording. One also includes QCB "should" timeframes.

| ID | Action | Source wording |
|---|---|---|
| **E01** | **Keep an AI Register of every AI system, with the QCB fields and the high-risk classification** | Must |
| **E02** | **Disclose to QCB the high-risk criteria and a high-level risk and impact assessment, and the full AI Register every year and on request** | Must |
| **E03** | **Obtain QCB approval before launching AI as a Provider, a material change, a high-risk AI agreement, a cloud arrangement or a material cloud arrangement** | Must |

Behind them: 71 QCB rows and 20 national rows, labelled Must / Mixed / Should (QCB) and REQUIRED / CONDITIONAL / RECOMMENDED / GOOD PRACTICE (national).

QUESTIONS 3 AND 5

# Bands, approvals, appetite

Map your own ratings to the national EISRMF bands. High and Severe risks are flagged for out-of-band reporting to NCSA.

| National band | What the band means (EISRMF, Figure 5) |
|---|---|
| **Very Low** | Accept and monitor. Review if circumstances change. |
| **Low** | Monitor periodically. No urgent action required. |
| **Medium** | Treat where above appetite; otherwise manage by control. |
| **High** | Immediate intervention. Treatment plan required. |
| **Severe** | Immediate intervention. Escalate to NCSA out of band. |

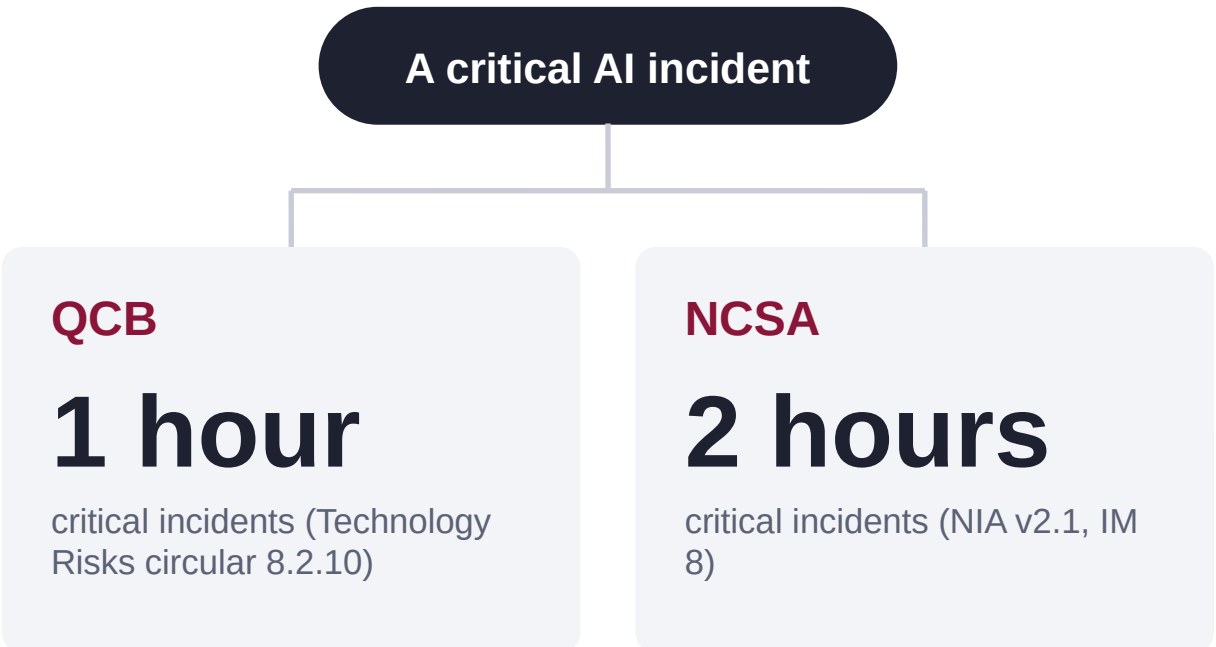
**Approver for each band:** set by the bank, in addition to the risk owner

**Risk appetite by consequence area:** scenarios above appetite are flagged

**Risk acceptance log:** review dates; incomplete or expired acceptances flagged

QUESTION 6

# Two regulators, one calendar




*Whether the 1-hour rule also covers NCSA is listed as a point to confirm.*

**One calendar for the rest:** QCB incident timeframes, the AI and Cloud Register disclosures, the NCSA risk register, treatment plan and attestation, and out-of-band reports for High and Severe risks.

QUESTION 7

# Evidence, and how it was checked

Status, evidence and owner columns for every requirement, Statement of Applicability mappings and a compliance summary.

- Every citation checked against the QCB and NCSA source texts
- Second review against the source texts before release
- Five open points listed openly, not guessed
- Built with AI assistance

# Get it free

Workbook (.xlsx) · 22-page guidance · 3-page quick guide

**github.com/ElNaboulsi/ai-security-risk-addon-qatar-banks**

- Free to use and adapt; please credit the source
- Advisory only: the official texts prevail
- Feedback welcome in the comments

**Abed Al Rahman Naboulsi**